LAB 5

STATIC CODE ANALYSIS

Restaurant Order System

Student	Bheema Varshini
SRN	PES2UG24CS115
Tools	Pylint, Bandit, Flake8
Repository	github.com/varshinibheema8/Lab5-Static-Code-Analysis

Before-and-after static analysis evidence and successful execution output.

1. Summary of Results

The original Python program was scanned using Pylint, Bandit, and Flake8. The source code was then revised and scanned again. The screenshots in this report show the captured tool outputs before and after the changes.

Tool	Before	After
Pylint	4.81/10	**10.00/10**
Bandit	5 findings: 2 high, 1 medium, 2 low	**No issues identified**
Flake8	9 findings	**No violations printed**

2. Pylint — Before

```
(venv) C:\Users\varsh\L5_49_restaurant_order_system>type pylint_before.txt
************* Module restaurant_order_system_original
restaurant_order_system_original.py:18:0: C0301: Line too long (110/100) (line-too-long)
restaurant_order_system_original.py:83:0: C0304: Final newline missing (missing-final-newline)
restaurant_order_system_original.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:15:0: C0103: Function name "placeTableOrder" doesn't conform to snake_case nam
ing style (invalid-name)
restaurant_order_system_original.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
restaurant_order_system_original.py:19:21: C0209: Formatting a regular string which could be an f-string (consider
-using-f-string)
restaurant_order_system_original.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:23:0: C0103: Function name "voidTableOrder" doesn't conform to snake_case nami
ng style (invalid-name)
restaurant_order_system_original.py:26:4: W0702: No exception type(s) specified (bare-except)
restaurant_order_system_original.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:30:0: C0103: Function name "checkTableStatus" doesn't conform to snake_case na
ming style (invalid-name)
restaurant_order_system_original.py:32:7: C0121: Comparison 'orders.get(table_id) == None' should be 'orders.get(t
able_id) is None' (singleton-comparison)
restaurant_order_system_original.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simpli
fiable-if-statement)
restaurant_order_system_original.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-inden
t the code inside it (no-else-return)
restaurant_order_system_original.py:31:4: W0612: Unused variable 'service_tax' (unused-variable)
restaurant_order_system_original.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:40:0: C0103: Function name "calculateDiscountedBill" doesn't conform to snake_
case naming style (invalid-name)
restaurant_order_system_original.py:42:16: W0123: Use of eval (eval-used)
restaurant_order_system_original.py:41:4: W0612: Unused variable 'base_bill' (unused-variable)
restaurant_order_system_original.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified
-encoding)
restaurant_order_system_original.py:55:8: R1732: Consider using 'with' for resource-allocating operations (conside
r-using-with)
restaurant_order_system_original.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system_original.py:61:24: W0621: Redefining name 'orders' from outer scope (line 8) (redefined-ou
ter-name)
restaurant_order_system_original.py:63:8: W0612: Unused variable 't' (unused-variable)
restaurant_order_system_original.py:6:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 4.81/10
```

Figure 1. Original Pylint output, including the 4.81/10 score.

3. Pylint — After

```
(venv) C:\Users\varsh\L5_49_restaurant_order_system>type pylint_report.txt

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 4.81/10, +5.19)
```

Figure 2. Final Pylint score: 10.00/10, up from 4.81/10.

4. Bandit — Before

```
(venv) C:\Users\varsh\L5_49_restaurant_order_system>type bandit_before.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.0
Run started:2026-10-14 06:30:28.835926+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\restaurant_order_system_original.py:26:4
25              del orders[table_id]
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\restaurant_order_system_original.py:42:16
41          base_bill = orders[table_id]["bill"]
42          net_total = eval(promo_expr)
43          return net_total

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\restaurant_order_system_original.py:47:11
46      def generate_ticket_hash(table_id):
47          return hashlib.md5(table_id.encode()).hexdigest()
48

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\restaurant_order_system_original.py:51:11
50      def generate_pos_pin():
51          return random.randint(1000, 9999)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\restaurant_order_system_original.py:58:4
57          f.close()
58          os.system("echo Ticket sent to kitchen printer: " + filename)
59

--------------------------------------------------

Code scanned:
        Total lines of code: 61
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):

(venv) C:\Users\varsh\L5_49_restaurant_order_system>0
```

Figure 3. Original Bandit output showing five findings.

5. Bandit — After

```
(venv) C:\Users\varsh\L5_49_restaurant_order_system>type bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.13.0
Run started:2026-10-14 06:22:23.911650+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 105
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

Figure 4. Final Bandit output: no issues identified.

6. Flake8 — Before

```
(venv) C:\Users\varsh\L5_49_restaurant_order_system>type flake8_before.txt
restaurant_order_system_original.py:6:1: F401 'math' imported but unused
restaurant_order_system_original.py:18:80: E501 line too long (110 > 79 characters)
restaurant_order_system_original.py:19:80: E501 line too long (85 > 79 characters)
restaurant_order_system_original.py:26:5: E722 do not use bare 'except'
restaurant_order_system_original.py:31:5: F841 local variable 'service_tax' is assigned to but never used
restaurant_order_system_original.py:32:29: E711 comparison to None should be 'if cond is None:'
restaurant_order_system_original.py:41:5: F841 local variable 'base_bill' is assigned to but never used
restaurant_order_system_original.py:75:80: E501 line too long (80 > 79 characters)
restaurant_order_system_original.py:83:7: W292 no newline at end of file
```

Figure 5. Original Flake8 output showing nine findings.

7. Flake8 — After



Figure 6. Final Flake8 command; the report produced no violation lines.

8. Program Execution

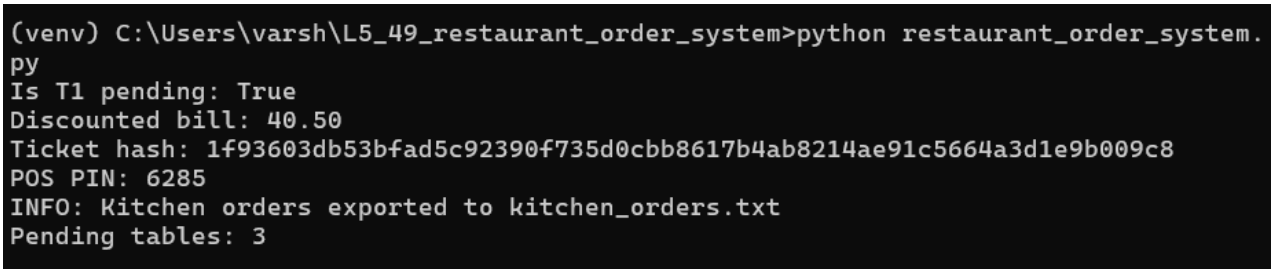


Figure 7. Corrected program executed and printed status, bill, hash, PIN, export, and pending-table output.

9. Main Issues and Fixes

Original issue	Fix applied
Unsafe eval()	Removed dynamic evaluation and validated discount input.
os.system() shell execution	Removed shell execution and used pathlib-based file handling.
Weak MD5 hashing	Replaced MD5 with SHA-256.
Pseudo-random PIN generation	Used the secrets module.
Bare exception and mutable default list	Improved error/control flow and changed the default list to None.
Unused variables/imports and style issues	Removed unused items and improved naming, documentation, and formatting.
File handling without context manager/encoding	Used a context manager and UTF-8 encoding.

10. Reflection and Conclusion

Static analysis vs. testing: Static analysis examines source code without running it; testing executes the program with inputs. They complement each other.

Tool roles: Pylint checks code quality and common programming problems, Bandit checks common security weaknesses, and Flake8 checks style and certain coding errors.

Conclusion: The original analysis identified security, quality, and style problems. After revisions, Pylint scored 10.00/10, Bandit identified no issues, and Flake8 printed no violations. The program also ran successfully in the captured terminal. Static analysis does not replace functional testing or manual review.

GitHub repository: https://github.com/varshinibheema8/Lab5-Static-Code-Analysis